GRC103 Lab 2: Ransomware Risk Treatment, Northbridge Community Health

Name	**Oluwatosin Olajubu**
Registration Number	**C11/26/CGRCE/17602**
Source	Health Service Executive (2025) *Cyber-attack and HSE response.* Available at: https://www2.hse.ie/services/cyber-attack/what-happened/ (page last reviewed 1 December 2025; accessed 09 November 2026)
SpreadSheet Link	**Risk Register Budget &Insurance**

Real HSE facts are labelled **REAL**; Northbridge, prices, insurance terms and the later change are fictional **ASSUMPTIONS**. Calculations and formulas are in the attached spreadsheet.

Task 1: Risk register and prioritisation

ID	Risk / asset	Threat and weakness (assumed)	Business impact	Owner	L	I	Score	Rating
R1	**Service disruption** — Booking, scheduling and patient-record systems across the 3 clinics	Ransomware encrypts files and systems. Recovery never tested; legacy dependencies not reviewed; flat network (assumptions)	Essential bookings stop; care delayed or cancelled across all clinics	Chief Operating Officer	4	5	20	**Critical**
R2	**Sensitive-data loss** — Patient health and personal records	Data copied and leaked or used for extortion. No MFA or access review in place (assumption); no segmentation	Patient harm, regulatory breach notification, loss of trust, legal cost	Data Protection Officer	3	5	15	**High**
R3	**Unnecessary supplier exposure** — Unused but enabled supplier workflow and its credentials	Attacker abuses a forgotten third-party access path. Workflow enabled yet unused, so unmonitored and unowned (assumption)	Free foothold into the network that serves no business purpose	Head of IT	4	3	12	**High**
R4	**Delayed detection** — Mailboxes, endpoints and network activity	Attacker works undetected after a phishing foothold. Phishing reports have no escalation owner; no managed monitoring (assumptions)	Longer attacker dwell time; larger damage before containment	Head of IT	4	4	16	**High**

Scales (classroom): likelihood 1-5 x impact 1-5; Low 1-4, Medium 5-9, High 10-16, Critical 17-25. Critical risks cannot be accepted; High risks go to the board.

Explanations: R1 L4: recovery is untested and entry paths exist (phishing, unused supplier workflow), so a successful attack is likely. I5: essential bookings must continue and all three clinics depend on the same systems, so a prolonged outage is the worst credible impact. 4 x 5 = 20 = Critical: cannot be accepted.

R2 L3: theft needs intrusion plus exfiltration, possible but not certain. I5: health data is highly sensitive and a breach reaches patients directly. 3 x 5 = 15 = High: board escalation required.

R3 L4: an enabled, unused and unwatched path is an easy target. I3: it gives a foothold rather than direct harm, so impact depends on what an attacker does next. 4 x 3 = 12 = High: board escalation required.

R4 L4: without an owner for phishing reports, warning signs are likely to be missed. I4: late detection raises the size of the incident but is not itself the final harm. 4 x 4 = 16 = High: board escalation required.

REAL facts (HSE official account):

1. A phishing email reached an HSE user in March 2021; opening its attachment secretly downloaded malware, and ransomware was triggered in May 2021. This supports **R4 and R3**: a phishing entry route and roughly two months between foothold and attack.
2. Files were encrypted and patient and staff information was illegally accessed and copied; HSE notified 90,000 people and paid no ransom. This supports **R1 and R2**: encryption stops services, and copied data is a harm that restoring backups cannot undo.

ASSUMPTIONS (fictional Northbridge): an unused supplier workflow is enabled; recovery is untested; phishing reports have no escalation owner; essential bookings must continue; prices and insurance terms are classroom inputs.

Task 2: Initial treatment portfolio (budget $100,000)

ID	Option	Strategy	Cost	Initial decision	Risks addressed	Reason
A	Retire the unused supplier workflow	Avoidance	$5,000	**Selected**	R3 (also R4)	Selected. Cheapest option; removes the exposure entirely because the workflow has no business use.
B	MFA rollout and account access review	Mitigation	$25,000	**Selected**	R2, R4 (also R3)	Selected. Limits stolen-credential abuse and removes stale access; protects patient data.
C	Protected backups, restoration tests and recovery plan	Mitigation	$30,000	**Selected**	R1 (also R2)	Selected. The only option that treats the Critical risk R1 directly.
D	Managed detection and incident escalation service	Mitigation	$35,000	Rejected	R4 (also R2)	Rejected for year 1. $35,000 does not fit beside B, C and G. R4 is partly treated by E and accepted for 90 days.
E	Targeted awareness training and reporting process	Mitigation	$10,000	**Selected**	R4 (also R2)	Selected. Cheap and directly closes the missing escalation owner for phishing reports.
F	Network segmentation and legacy dependency review	Mitigation	$40,000	Rejected	R1, R2	Rejected for year 1. Largest cost and its benefit is indirect; it would exhaust the budget on its own.
G	Illustrative cyber insurance ($25,000 deductible; $250,000 cap)	Transfer	$20,000	**Selected**	Financial consequence of R1, R2 only	Selected. Caps financial loss above the $25,000 deductible while controls are being built. It does not restore bookings and does not transfer accountability.
Total selected: $90,000. Remaining budget: $10,000 (A+B+C+E+G = 5,000+25,000+30,000+10,000+20,000)						

Strategies.

a. **Avoidance:** A removes the supplier exposure outright.

b. **Mitigation:** B, C and E cut likelihood or impact of R1, R2 and R4.

c. **Transfer (assessed):** G pays only above the $25,000 deductible, up to $250,000, only for covered claims, and does not restore bookings, so it supports but never replaces controls; it is selected to cap financial loss while controls are built.

d. **Time-limited acceptance:** R4's residual (no 24/7 monitoring because D is rejected) is accepted for 90 days to 14 Feb 2027, owner Head of IT, simulated approver Board Chair, with early review if a phishing report is not triaged within 4 working hours, a restore retest fails or compromise is suspected. R1 (Critical) is not accepted.

e. **Accountability:** neither outsourcing nor insurance removes Northbridge's accountability for patient safety and data protection.

Task 3: Retained financial exposure under option G

Scenario	Loss	Insurer payment = MIN(MAX(loss - 25,000, 0), 250,000)	Retained loss	Premium	Total first-year outlay
Covered loss $180,000	$180,000	MIN(MAX(180,000 - 25,000, 0), 250,000) = **$155,000**	180,000 - 155,000 = **$25,000**	$20,000	25,000 + 20,000 = **$45,000**
Covered loss $400,000	$400,000	MIN(MAX(400,000 - 25,000, 0), 250,000) = **$250,000**	400,000 - 250,000 = **$150,000**	$20,000	150,000 + 20,000 = **$170,000**
Excluded claim $180,000	$180,000	$0 (claim not covered)	**$180,000**	$20,000	**$200,000**
Excluded claim $400,000	$400,000	$0 (claim not covered)	**$400,000**	$20,000	**$420,000**

If the claim is excluded, Northbridge bears the entire loss (the board and owners, in practice patients through cut or delayed services), and the premium is also spent. At $400,000 the $250,000 cap leaves $150,000 retained. These are fictional policy terms; no real purchase is needed.

Task 4: Response to the change (restore test fails; paper bookings last only four hours; option B rises to $35,000)

ID	Option	Revised cost	Revised decision	Reason
A	Retire the unused supplier workflow	$5,000	**Selected**	Kept. Still the cheapest, fastest risk reduction.
B	MFA rollout and account access review	$35,000	**Selected**	Kept at the higher $35,000. MFA remains the main control against R2; deferring it would leave data theft barely treated.
C	Protected backups, restoration tests and recovery plan	$30,000	**Selected**	Kept as first priority. The failed restore test proves recovery is not yet effective, so it is remediated and retested before any credit is taken.
D	Managed detection and incident escalation service	$35,000	Deferred	Deferred. Remains the next priority if the recovery reserve is not needed (needs board funding).
E	Targeted awareness training and reporting process	$10,000	**Selected**	Kept. Low cost and closes a known gap.
F	Network segmentation and legacy dependency review	$40,000	Deferred	Deferred to year 2 planning.
G	Illustrative cyber insurance ($25,000 deductible; $250,000 cap)	$20,000	Deferred	Deferred. Insurance pays money, not clinic bookings; $20,000 is ring-fenced for recovery instead. Board must accept the uninsured exposure (see Insurance sheet).
Committed $80,000 (A 5,000 + B 35,000 + C 30,000 + E 10,000) + $20,000 ring-fenced recovery reserve = $100,000, same budget				

What changes: G is dropped and its $20,000 becomes a recovery reserve; C becomes the first priority, is remediated and retested, and earns no credit until it passes; paper-booking procedures are extended and drilled.

What is deferred: D (managed detection), F (segmentation) and G (insurance).

Owners of remaining risks: R1 Chief Operating Officer; R2 Data Protection Officer; R3 Head of IT; R4 Head of IT.

Escalate to the board:

a. running without cyber insurance while recovery is unproven (a $180,000 loss would be retained in full, $155,000 more than with G; a $400,000 loss $250,000 more);
b. the 90-day acceptance of delayed detection;
c. R1 stays High after treatment. Reserve release needs CFO and COO approval; if unused by 15 Dec it returns to the board for D or G.

Task 5: 30-day treatment plan (16 Nov to 15 Dec 2026)

Ref	Action	Owner	Cost	Target	Effectiveness test
P1	Board approves revised portfolio, reserve rules and the R4 acceptance	Board Chair (simulated) / CEO	$0	16 Nov	Signed minutes and signed acceptance records exist.
P2	Retire the unused supplier workflow (option A)	Head of IT	$5,000	20 Nov	Workflow disabled; supplier confirms in writing; 7-day log check shows no use and no open firewall rule.
P3	Name the phishing escalation owner, publish the reporting process and run targeted training (option E)	Head of IT	$10,000	27 Nov	Simulated phishing test: every report triaged by the named owner within 4 working hours; reporting rate recorded as baseline.
P4	MFA for admin, remote and email accounts, then all staff, plus account access review (option B)	Head of IT	$35,000	15 Dec	Coverage report shows 100% of admin and remote accounts enforced; a login without MFA is blocked; access review signed by system owners.
P5	Fix the restore failure, then retest restoration of booking and patient-record systems from protected backups (option C)	Chief Operating Officer	$30,000	4 Dec	Witnessed restore in an isolated environment, timed against the recovery target; signed result. Not credited as effective until it passes.
P6	Extend paper-booking procedures beyond four hours and drill them (inside option C recovery plan)	Chief Operating Officer	$0	27 Nov	Unannounced 8-hour paper drill at one clinic completes all essential bookings; gaps logged and fixed.
P7	Hold the recovery reserve; release only with CFO and COO approval if the retest fails again	Chief Financial Officer	$20,000 (reserve)	4 Dec	Reserve log shows every release, reason and approver. If unused, it returns to the board on 15 Dec for decision on options D or G.
P8	Day-30 re-score of the four risks and report to the board	Risk Manager	$0	15 Dec	Residual scores changed only where the linked control passed its test; untested controls get no credit.

ID	Initial	Proposed residual	Assumptions (untested controls are not credited)
R1	4x5=20 Critical	**3x5=15 High**	A and B lower the chance of entry. C is NOT credited until the retest passes. Impact stays 5 because paper bookings last only four hours until the drill proves otherwise. Target if retest and drill pass: L2 x I4 = 8 (Medium), not yet credited. Critical rating cannot be accepted, so it stays on treatment with board escalation.
R2	3x5=15 High	**2x5=10 High**	B (MFA and access review) lowers the chance that stolen credentials give access. Impact stays 5 because segmentation (F) and managed detection (D) are deferred, so copied data would still be exposed. MFA is credited only after its coverage test.
R3	4x3=12 High	**1x3=3 Low**	A removes the exposed path. Credit taken only after the P2 verification test passes; until then the score stays 12. Other supplier paths are assumed not to exist.
R4	4x4=16 High	**3x4=12 High**	E gives phishing reports an owner and a process. No 24/7 monitoring (D deferred), so detection is still slow. Residual High, formally accepted for 90 days with board escalation.

Acceptance record (R4): owner Head of IT; expiry 14 Feb 2027; review triggers as in Task 2; simulated approver Board Chair; compensating controls: E, B and the day-30 re-score.

Decision records

Record	Content
Initial decision (before change)	Select A, B, C, E, G = $90,000; remaining $10,000. Reject D and F. Accept R4 residual for 90 days. R1 Critical, not accepted.
Revised decision (after change)	Select A, B ($35,000), C, E = $80,000 committed + $20,000 reserve = $100,000. Defer D, F, G. Escalate the three decisions listed in Task 4.

Board memo

Subject: Ransomware risk: approval of a $100,000 treatment plan and a 90-day risk acceptance

To: Board of Directors, Northbridge Community Health
From: Oluwatosin Olajubu
Date: 16 November 2026

Dear Board members,

We are asking you to approve how Northbridge spends its $100,000 cyber budget this year, and to formally accept one risk for 90 days.

Why this matters now. Our latest restoration test failed, and our clinics can run on paper for only four hours. The 2021 HSE attack shows what that gap can cost: a phishing attachment opened in March led to ransomware in May, and patient data was copied. Our own weaknesses (an unused supplier connection, untested recovery, and no one owning phishing reports) are exercise assumptions, not HSE facts, but they point to the same exposure.

What we propose. Spend $80,000 on four measures: retiring the unused supplier workflow ($5,000), multi-factor authentication and an access review ($35,000, up from $25,000), protected backups with proper restore testing ($30,000), and phishing training with a clear reporting route ($10,000). The remaining $20,000 is held in reserve to fix recovery if the retest fails again. Managed detection, network segmentation and insurance are deferred.

What remains uncertain. Service disruption stays high-risk until a witnessed restore passes, due 4 December. Patient-data loss also remains high. We ask you to accept delayed detection for 90 days, to 14 February 2027, with the Head of IT accountable. Without insurance, a $180,000 loss would fall entirely on Northbridge, and responsibility for these decisions stays with the board.

Please approve the plan and the acceptance.